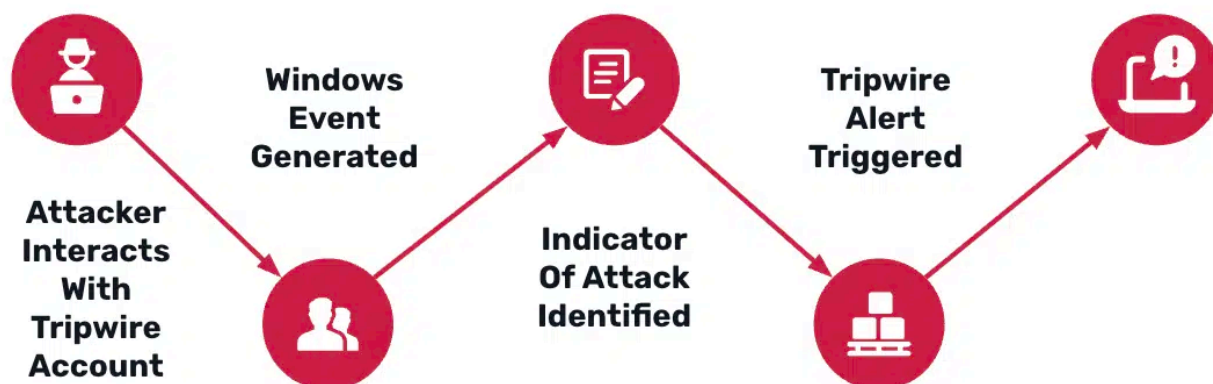


Defending with AD Tripwires: GOAD Walkthrough

 horizon3.ai/attack-research/defending-with-ad-tripwires-goad-walkthrough

Justin Cady

January 26, 2026



From Attacker Story to Defender Story

[Part 1](#), *The Quiet Attack Path*, showed how attackers enumerate Active Directory (AD), walked through the attacker's first fifteen minutes inside GOAD (Game of Active Directory). The key lesson: native Kerberos and LDAP activity looks completely normal until it is too late. Part 2 flips to the defender's point of view. We deploy AD Tripwires inside the same GOAD lab and show how a small set of purpose-built tripwire accounts produces deterministic alerts the moment an attacker touches credential material.

TL;DR

- **What are AD Tripwires?** Purpose-built tripwire accounts (exposed credentials, Kerberoasting, AS-REP) seeded in AD to light up the second an attacker pokes credential material.
- **How they work:** Watch Windows Security Events 4625, 4768, 4769, and 4771 for any reference to those accounts—any hit is attacker-only signal.
- **Why it matters:** Deterministic, low-noise telemetry that fires at the earliest step of the Attack Path and feeds right into Splunk Cloud, Microsoft Sentinel, or your SIEM/EDR.
- **What we show:** A GOAD walkthrough that pairs each tripwire account with the exact attacker move from Part 1 so you can see detection, event payload, and alert response end to end.

Setting the Stage: GOAD's Real Victims

Before adding any tripwires, GOAD already contains vulnerable production accounts—the same ones our autonomous operations abused in Part 1.

Account	Why it is vulnerable	What the attacker does with it
samwell.tarly	Cleartext password exposed via SMB null session	Provides first authenticated domain foothold
jon.snow	Service account with SPN, weak password hygiene	Classic Kerberoasting target once a foothold exists
missandei	Kerberos pre-authentication disabled (legacy setting)	Enables unauthenticated AS-REP Roasting

These are “real” users. Touching them might blend into legitimate helpdesk noise, which is exactly why defenders struggle to spot the attack path. We introduce tripwire accounts to change the story.

The Tripwire Cast (Safe by Design)

Tripwire accounts are planted specifically to catch reconnaissance. They never hold privileges, are never tied to applications, and use long, random passwords so that any interaction is unambiguously hostile.

Tripwire Type	Bait the attacker sees	Signal we monitor
Exposed Credentials	Friendly Description field that “leaks” a fake secret	Failed logon (4771/4625) using the fake password
Kerberoasting	Legit-looking service account with a safe SPN	TGS request (4769) for that SPN
AS-REP Roasting	Account with pre-auth disabled	AS-REQ / TGT request (4768, sometimes 4771)

Because these accounts are never used by production workflows, baseline noise rounds to zero. If they fire, someone is enumerating AD with malicious intent.

Turning Recon into Deterministic Alerts

AD Tripwires subscribes to a handful of Windows Security Events on the Domain Controller. Each alert contains the tripwire account, source host/user, Domain Controller, timestamp, and event payload that matters for triage. The three event families to watch:

1. **Failed logons (4625 / 4771)** — exposed-credential tripwires when someone tries the fake Description password.

2. **Service ticket requests (4769)** — Kerberoasting tripwire SPNs requested for offline cracking.
3. **Authentication ticket requests (4768 / optional 4771)** — AS-REP tripwires where pre-auth is disabled.

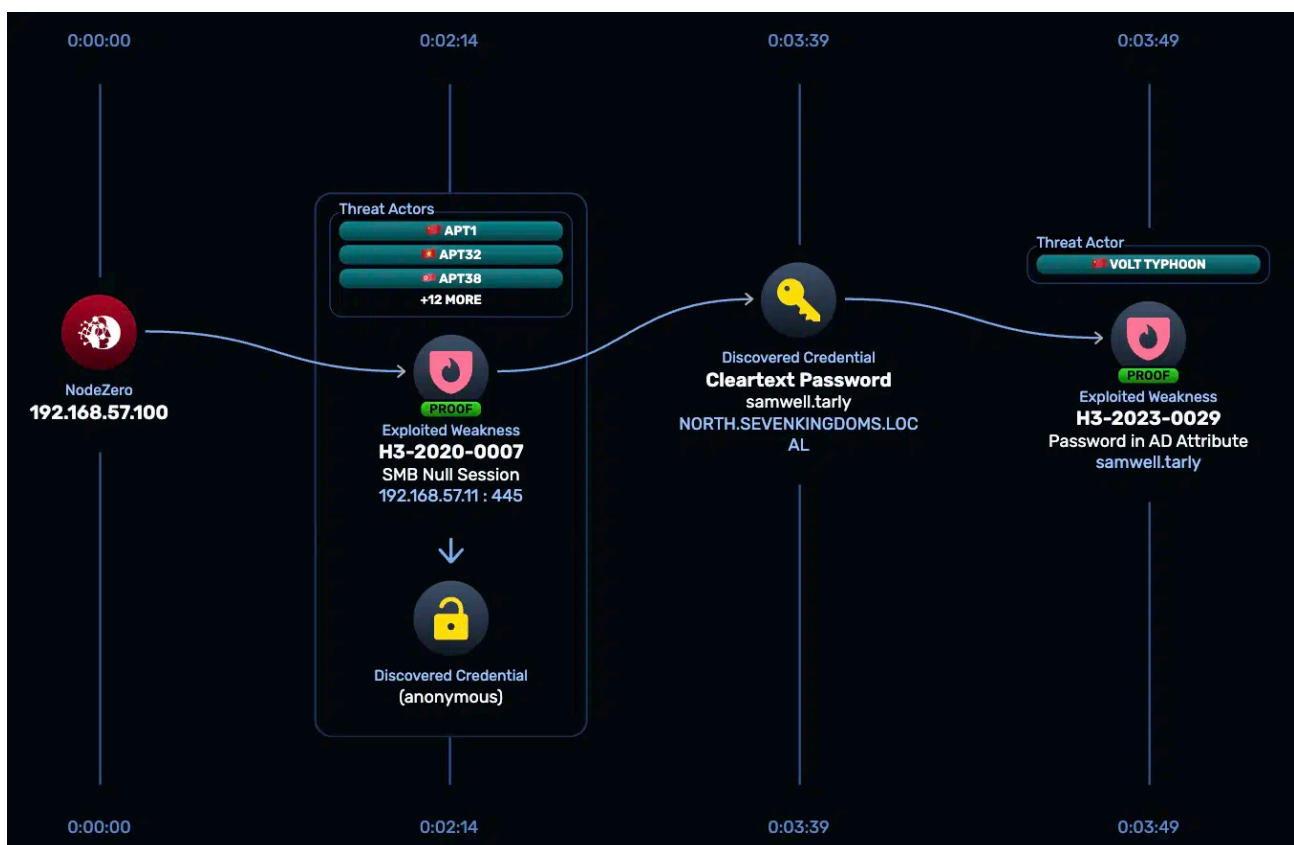
That is the entire playbook: plant the lures, monitor the four event IDs, forward the alerts to Splunk Cloud, Microsoft Sentinel, or your SIEM/EDR, and respond immediately.

GOAD Walkthrough — Three Mini-Stories

The examples below come from a GOAD (Game of Active Directory) environment—a widely used enterprise-style reference architecture for AD security validation. We deployed AD Tripwires alongside the existing GOAD infrastructure, then ran autonomous pentesting operations to demonstrate how tripwire accounts surface attacker behavior in real time.

Scenario 1: Exposed Credentials Tripwire

Attack Path



This attack path shows how quickly an exposed credentials tripwire account lights up:

- **00:00 → SMB null session (H3-2020-0007).** Anonymous access to 192.168.57.11:445 yields discovery of the anonymous credential.

- **00:02 → Cleartext password exposure (H3-2023-0029).** The session uncovers a cleartext password for samwell.tarly stored in an Active Directory attribute.
- **00:03 → Domain user ready.** With valid credentials, the operator now has authenticated domain access to pivot into Kerberoasting or AS-REP Roasting.

Tripwire Configuration



Tripwire account details:

- **Account name:** svc_backup_legacy
- **Description field:** pw: iMhZFDkLYzR7nKaIhtuH
- **Actual password:** Long complex randomly generated string (not iMhZFDkLYzR7nKaIhtuH)
- **Group membership:** Domain Users only (no privileges)

What the Attacker Sees

During Lightweight Directory Access Protocol (LDAP) enumeration, the attacker harvests the Description field and attempts to authenticate with iMhZFDkLYzR7nKaIhtuH.

```
PS C:\Users\administrator> Get-ADUser -Filter "SamAccountName -eq 'svc_backup_legacy'" -Properties Description |
>> Select-Object SamAccountName,Description | Format-List

SamAccountName : svc_backup_legacy
Description      : pw: iMhZFDkLYzR7nKaIhtuH
```

```
>> } catch {}
New-PSDrive : The user name or password is incorrect
At line:4 char:5
```

Windows Security Event

When the attacker tries the fake password, the Domain Controller logs a failed logon:

Security Number of events: 90,892 (!) New events available				
Keywords	Date and Time	Source	Event ID	Task Category
Audit Failure	11/24/2025 8:15:11 PM	Microsoft Windows security auditing.	4771	Kerberos Authentication Service
Audit Success	11/24/2025 8:11:59 PM	Microsoft Windows security auditing.	4769	Kerberos Service Ticket Operations
Audit Success	11/24/2025 8:11:59 PM	Microsoft Windows security auditing.	4768	Kerberos Authentication Service
Audit Success	11/24/2025 8:11:59 PM	Microsoft Windows security auditing.	4768	Kerberos Authentication Service
Audit Success	11/24/2025 8:11:59 PM	Microsoft Windows security auditing.	4769	Kerberos Service Ticket Operations
Audit Success	11/24/2025 8:11:59 PM	Microsoft Windows security auditing.	4769	Kerberos Service Ticket Operations

Key fields:

- **Event ID:** 4771 (Kerberos pre-authentication failed)
- **TargetUserName:** svc_backup_legacy
- **ServiceName:** krbtgt/NORTH
- **FailureCode:** 0x18 (bad password)
- **Ticket Options:** 0x40810010 (indicates pre-auth failure)
- **Client Address:** 192.168.57.100 (attacker host)

Platform Alert

Trippwire Alerts

Exposed Credential Account from north.sevenkingdoms.local was tripped

Mark as Read

Actor Details

Tripped On

Nov 24, 2025, 3:07 PM

Source IP

192.168.57.100

Reporting Domain Controller

dc01.north.sevenkingdoms.local

Windows Event

4771 Kerberos pre-authentication failed

Trip Action

The actor failed login using the Kerberos authentication protocol, indicating they might have used brute force or password guessing against the tripwire account.

Tripwire Details

Tripwire Origin

north.sevenkingdoms.local

Tripwire ID

svc_backup_legacy@north.sevenkingdoms.local

Tripwire Type

Active Directory - Exposed Credential Account

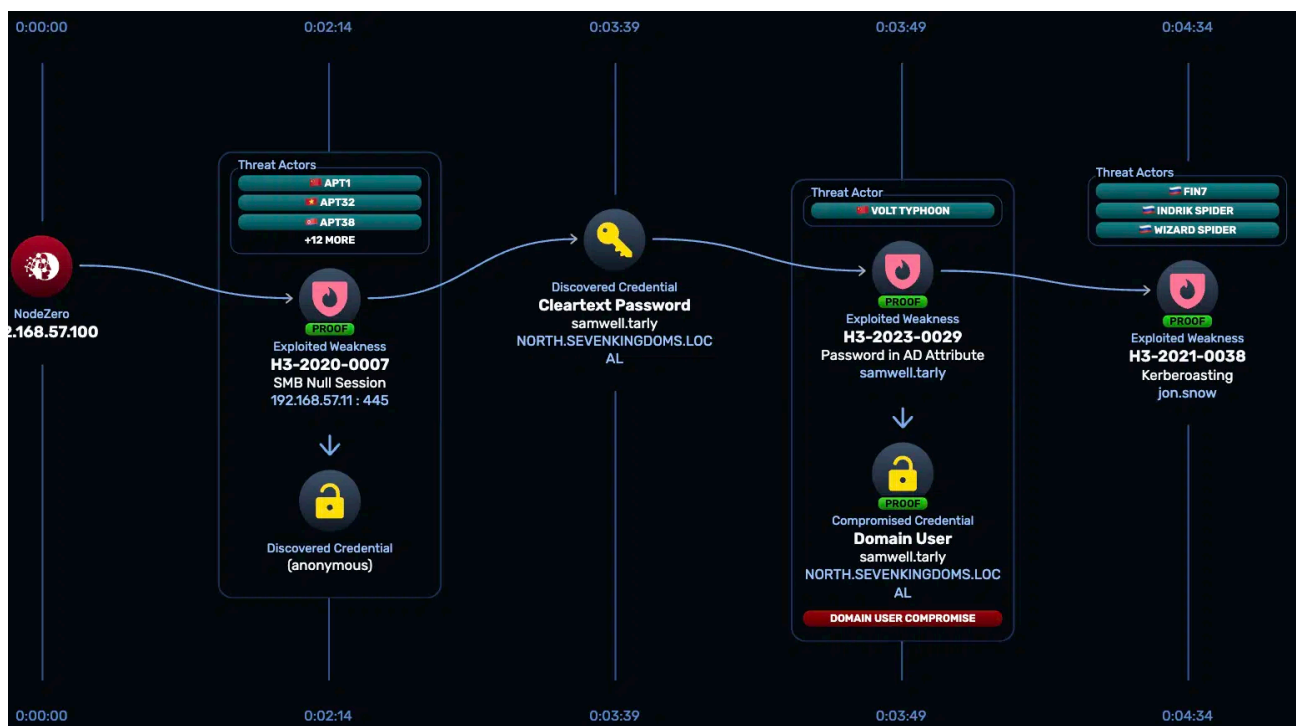
Description

This tripwire is an account with a fake password in its description, targeting attackers who look at metadata to find easily-compromised accounts to escalate privileges and move laterally. The attacker will see the password, think it's a security mistake, and try to log into the account. Since no one should be using the tripwire account, any login attempt will trigger the alert. [Learn more about detecting domain user scraping.](#)

Tripwire type	Exposed Credentials
Tripwire ID	svc_backup_legacy@north.sevenkingdoms.local
Tripwire origin	north.sevenkingdoms.local
Source IP	192.168.57.100
DC observed	DC01.north.sevenkingdoms.local
Timestamp	Oct 10, 2025 4:03 PM UTC
Windows Event	4771 Kerberos pre-authentication failed
Guidance	“The actor failed logon using the Kerberos authentication protocol, indicating they might have used brute force or password guessing against the tripwire account.”

Scenario 2: Kerberoasting Tripwire

Attack Path



This GOAD scenario shows the attacker flow from initial access to Kerberoasting:

- **00:00 → SMB null session.** Anonymous access to 192.168.57.11:445 (H3-2020-0007) yields an initial credential foothold.
- **00:02 → Domain metadata scrape.** The null session reveals the cleartext password for samwell.tarly stored in an Active Directory attribute (H3-2023-0029).
- **00:03 → Domain user compromise.** The recovered password grants an authenticated domain user session for samwell.tarly.
- **00:04 → Kerberoasting.** With domain user access, the attacker requests a service ticket for jon.snow (H3-2021-0038), exporting it for offline cracking.

Tripwire Configuration

```
PS C:\Users\administrator> Get-ADUser -Identity svc_sql_reporting -Properties ServicePrincipalName,MemberOf,PasswordLastSet |
>> Select-Object SamAccountName,ServicePrincipalName,PasswordLastSet,@{n='Groups';e={$_.MemberOf}}
```

SamAccountName	ServicePrincipalName	PasswordLastSet	Groups
svc_sql_reporting	{HTTP/test-webserver.internal}	11/20/2025 11:20:06 PM	

Tripwire account details:

- **Account name:** svc_sql_reporting
- **SPN:** HTTP/test-webserver.internal
- **Password last set:** 2025-11-20 23:20:06 UTC (long, randomly generated value)
- **Actual password:** 32-character randomly generated string
- **Group membership:** Domain Users only (no privileges)

What the Attacker Sees

During SPN enumeration, the attacker identifies svc_sql_reporting as a Kerberoastable target and requests a Ticket-Granting Service (TGS) ticket.

```
$ python3 GetUserSPNs.py north.sevenkingdoms.local/samwell.tarly \
> -dc-ip 192.168.57.11 \
> -target-svc svc_sql_reporting \
> -request \
> -outputfile svc_sql_reporting.hashes
Impacket v0.12.0 - Copyright 2024 SecureAuth Corporation
```

Password:

ServicePrincipalName	Name	MemberOf
PasswordLastSet	LastLogon	Delegation

HTTP/test-webserver.north.sevenkingdoms.local	svc_sql_reporting	CN=Domain Users,CN=Users,DC=north,DC=sevenkingdoms,DC=local
2025-11-21 15:04:11.000000	<no>	2025-11-20 23:20:06.000000

```
$krb5tgs$23$*svc_sql_reporting$NORTH.SEVENKINGDOMS.LOCAL$HTTP/test-
```



```
webserver.north.sevenkingdoms.local*$3a6f1b0c...:5b8c9d0e...
TGS hash written to svc_sql_reporting.hashes
```

Windows Security Event

When the attacker requests the service ticket, the Domain Controller logs the TGS request:

Security Number of events: 91,096				
Filtered: Log: Security; Source: ; Event ID: 4769. Number of events: 33,927				
Keywords	Date and Time	Source	Event ID	Task Category
 Audit Success	11/24/2025 10:01:59 PM	Microsoft Windows security auditing.	4769	Kerberos Service Ticket Operations
 Audit Success	11/24/2025 9:59:23 PM	Microsoft Windows security auditing.	4769	Kerberos Service Ticket Operations
 Audit Success	11/24/2025 9:56:59 PM	Microsoft Windows security auditing.	4769	Kerberos Service Ticket Operations
 Audit Success	11/24/2025 9:56:59 PM	Microsoft Windows security auditing.	4769	Kerberos Service Ticket Operations

Service Information:
Service Name: svc_sql_reporting

Key fields:

- **Event ID:** 4769 (A Kerberos service ticket was requested)
- **Service Name:** MSSQLSvc/sql-reporting.north.sevenkingdoms.local:1433
- **Account Name:** samwell.tarly (requesting user)
- **Client Address:** ::ffff:10.49.30.25
- **Ticket Encryption Type:** 0x17 (RC4-HMAC, common for Kerberoasting)

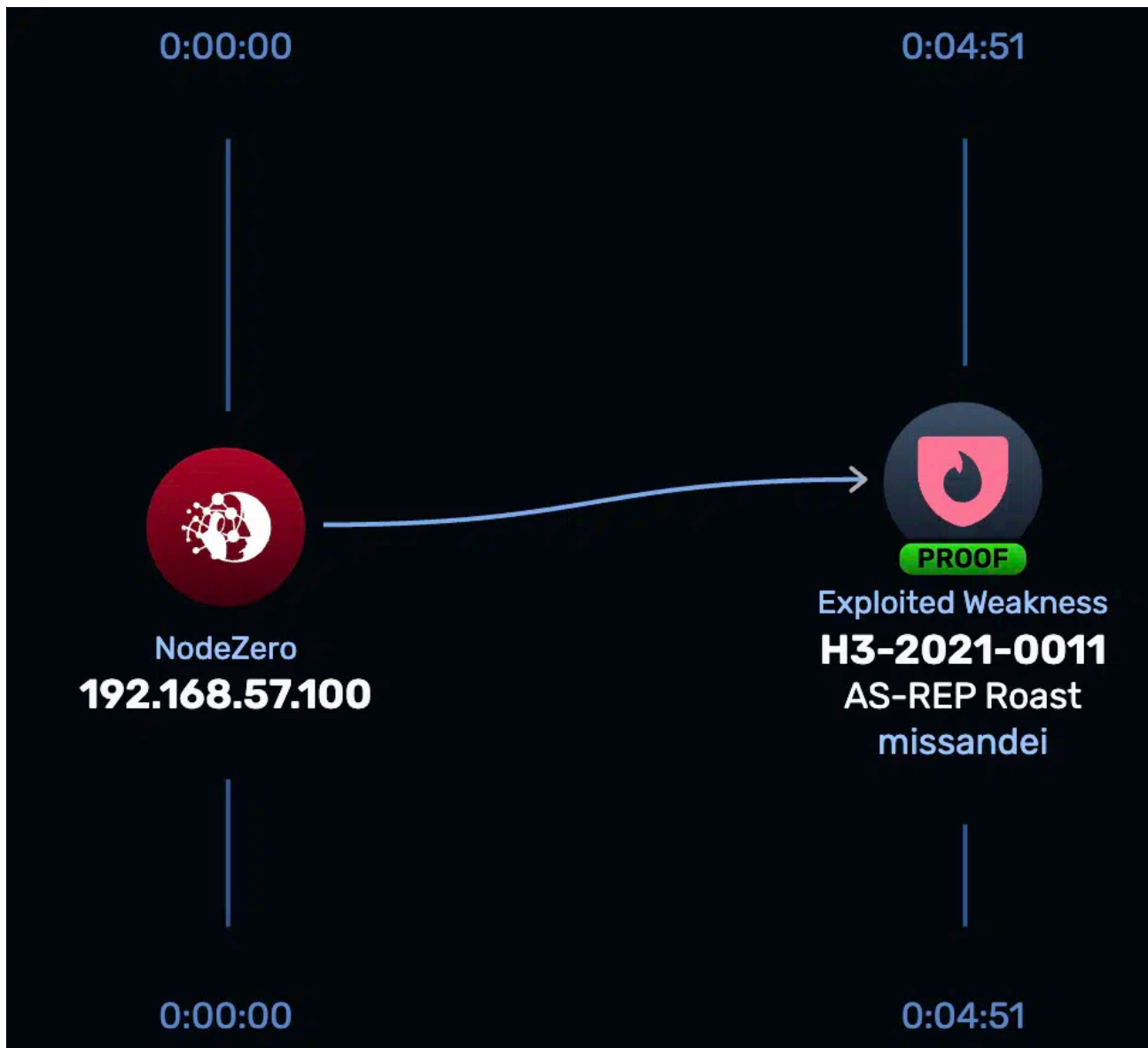
Platform Alert

Kerberoast Account from north.sevenkingdoms.local was tripped	
Mark as Read	
Actor Details	
Tripped On	Nov 24, 2025, 4:59 PM
Source IP	:ffff:10.69.30.25
Reporting Domain Controller	dc01.north.sevenkingdoms.local
Windows Event	4769 Kerberos service ticket (TGS) was requested
Trip Action	The actor successfully requested a TGS, indicating intent to crack the credential. Any ticket requests for this account indicate malicious activity.
Tripwire Details	
Tripwire Origin	north.sevenkingdoms.local
Tripwire ID	svc_sql_reporting@north.sevenkingdoms.local
Tripwire Type	Active Directory - Kerberos Account
Description	This tripwire is set up as a service account susceptible to kerberoasting, an attack that mirrors legitimate activity and used to escalate privileges for further compromise. The attacker requests a ticketing granting service (TGS) ticket to receive password hashes for kerberoastable accounts. Since the tripwire account should have no activity, relevant logs on the account will trigger an alert. Learn more about detecting Kerberoasting attacks.

Tripwire type	Kerberoasting
Tripwire origin	north.sevenkingdoms.local
Tripwire ID	svc_sql_reporting@north.sevenkingdoms.local
Source IP	::ffff:10.49.30.25
Reporting DC	dc01.north.sevenkingdoms.local
Timestamp	Nov 24, 2025 4:59 PM
Windows Event	4769 Kerberos service ticket (TGS) was requested
Guidance	“The actor successfully requested a TGS, indicating intent to crack the credentials. Any ticket requests for this account indicate malicious activity.”

Scenario 3: AS-REP Roasting Tripwire

Attack Path



This single-step GOAD path demonstrates unauthenticated AS-REP Roasting against a legacy account:

- **00:00 → NodeZero scope.** The operation begins from a beachhead at 192.168.57.100 with domain reconnaissance enabled.
- **00:04 → AS-REP Roast (H3-2021-0011).** Because missandei has Kerberos pre-authentication disabled, NodeZero requests an Authentication Service reply (AS-REP) without presenting credentials and captures the hash for offline cracking.

Tripwire Configuration

```
PS C:\Users\administrator> Get-ADUser -Identity svc_legacy_app -Properties DoesNotRequirePreAuth,MemberOf,PasswordLastSet
t |
>> Select-Object SamAccountName,DoesNotRequirePreAuth,PasswordLastSet,@{n='Groups';e={$_.MemberOf}}

SamAccountName DoesNotRequirePreAuth PasswordLastSet      Groups
-----
svc_legacy_app      True 11/20/2025 11:20:16 PM
```

Tripwire account details:

- **Account name:** svc_legacy_app
- **Pre-authentication:** Disabled (“Do not require Kerberos preauthentication” checked)
- **Actual password:** Long complex randomly generated string
- **Group membership:** Domain Users only (no privileges)

What the Attacker Sees

During user enumeration, the attacker identifies svc_legacy_app as having pre-authentication disabled and requests an AS-REP without credentials.

```
$ python3 GetNPUsers.py north.sevenkingdoms.local/ \
> -dc-ip 192.168.57.11 \
> -usersfile tripwire_users.txt \
> -format hashcat \
> -outputfile svc_legacy_app.asrep
Impacket v0.12.0 - Copyright 2024 SecureAuth Corporation

[*] No authentication required: attempting AS-REP roast
[*] Using KDC(s):
    192.168.57.11

[-] User missandei does not have UF_DONT_REQUIRE_PREAUTH set
[-] User svc_sql_reporting does not have UF_DONT_REQUIRE_PREAUTH set
[+] Got AS-REP for svc_legacy_app (hash written to svc_legacy_app.asrep)
$krb5asrep$23$svc_legacy_app@NORTH.SEVENKINGDOMS.LOCAL:1c7a...5e9d$cc2f0a9d9e0c0b3c
9...f8d1e2
```

Windows Security Event

When the attacker requests the AS-REP, the Domain Controller logs the authentication attempt:

Security Number of events: 91,161				
Filtered: Log: Security; Source: ; Event ID: 4768. Number of events: 30,689				
Keywords	Date and Time	Source	Event ID	Task Category
Audit Success	11/24/2025 10:38:21 PM	Microsoft Windows security auditing.	4768	Kerberos Authentication Service
Audit Success	11/24/2025 10:36:59 PM	Microsoft Windows security auditing.	4768	Kerberos Authentication Service
Audit Success	11/24/2025 10:36:59 PM	Microsoft Windows security auditing.	4768	Kerberos Authentication Service
Audit Success	11/24/2025 10:36:59 PM	Microsoft Windows security auditing.	4768	Kerberos Authentication Service
Event 4768, Microsoft Windows security auditing.				
General Details				
A Kerberos authentication ticket (TGT) was requested.				
Account Information:				
Account Name:		svc_legacy_app		

Key fields:

- **Event ID:** 4768 (A Kerberos authentication ticket (TGT) was requested)
- **TargetUserName:** svc_legacy_app
- **IpAddress:** 192.168.57.100
- **Ticket Options:** 0x50800000 (indicates pre-auth not required)

Platform Alert

Tripwire Alerts	
AS-REP Roast Account from north.sevenkingdoms.local was tripped	
Actor Details	
Tripped On	Nov 24, 2025, 5:38 PM
Source IP	:ffff:10.69.30.25
Reporting Domain Controller	dc01.north.sevenkingdoms.local
Windows Event	4768 Kerberos authentication ticket (TGT) was requested
Trip Action	The actor successfully requested a TGT, indicating intent to crack the credential. Any ticket requests for this account indicate malicious activity.
Tripwire Details	
Tripwire Origin	north.sevenkingdoms.local
Tripwire ID	svc_legacy_app@north.sevenkingdoms.local
Tripwire Type	Active Directory - AS-REP Roast Account
Description	This tripwire is set up to be susceptible to AS-REP roasting, an attack that mirrors legitimate activity and used to escalate privileges for further compromise. The attacker submits an Authentication Server Request (AS-REQ) that gets password hashes for accounts that don't require pre-authorization. Since the tripwire account should have no activity, relevant logs on the account will trigger an alert. Learn more about detecting AS-REP Roasting attacks.

Tripwire type	AS-REP Roasting
Tripwire origin	north.sevenkingdoms.local
Tripwire ID	svc_legacy_app@north.sevenkingdoms.local
Source IP	::ffff:10.49.20.25
Reporting DC	dc01.north.sevenkingdoms.local
Timestamp	Nov 24, 2025 5:38 PM
Windows Event	4768 Kerberos authentication ticket (TGT) was requested
Guidance	“The actor successfully requested a TGT, indicating intent to crack the credentials. Any ticket requests for this account indicate malicious activity.”

Why AD Tripwires Are Effective

- **Deterministic, not heuristic:** Tripwire accounts are dormant. Any touch is an attacker, period.
- **Earliest point in the Attack Path:** Alerts fire during reconnaissance/collection—well before domain admin or data access.
- **Low noise:** No production services reference these accounts; allowlist your own security scanners and you’re done.
- **Built for operations:** Alerts route through AD Tripwires into Splunk Cloud, Microsoft Sentinel, or your SIEM/EDR with the right context for playbooks.

Deploying and Validating in Your Environment

1. **Create the tripwire accounts** exactly as listed above—no privileges, random passwords, enticing metadata/SPNs/pre-auth toggles.
2. **Enable DC auditing** for 4625, 4768, 4769, and 4771. Forward those events (or the AD Tripwires alerts) into your logging pipeline.
3. **Test from a lab host:** Intentionally trigger each tripwire to confirm alert routing, timestamps, and enrichment.

4. **Fold alerts into playbooks:** Route as “Credential Access: Kerberos,” isolate the source, snapshot volatile data, and hunt for adjacent enumeration (LDAP, SMB, WinRM).
5. **Optionally forward raw DC security logs** with the same Event IDs if you want additional hunting context beyond the triaged alerts.
6. **Keep Kerberos hygiene tight:** ensure accurate time sync and hostname resolution; Kerberos drifts create false negatives.
7. **Enforce the safe-by-design rules:** no privileged group membership, no application bindings, long random passwords across all tripwire types.

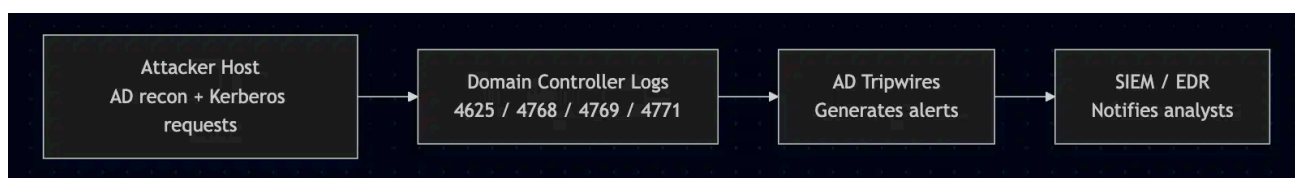
These steps require zero Active Directory re-architecture. You are simply adding three bait accounts, wiring the alerts, and treating them as an early-warning control that complements SIEM/EDR.

Why Not Just EDR?

Endpoint tools struggle with GOAD’s quiet attack path because native Kerberos and LDAP activity is indistinguishable from normal administrator work. Tripwire accounts change that math: they are never referenced by production services or users, so any authentication attempt or ticket request that names them shows up as a deterministic signal in Windows Security Events (4625, 4769, 4768, 4771).

AD Tripwires watches those logs (or receives them directly) and raises alerts the instant a failed logon, TGS request, or AS-REQ touches a tripwire account, dramatically shrinking false positives while flowing straight into Splunk Cloud, Microsoft Sentinel, or your SIEM/EDR. That telemetry closes the exact gap highlighted in Part 1—those stealthy Kerberoasting and AS-REP Roasting moves now leave a crisp, attributable trail that defenders can act on before the attacker escalates.

Architecture at a Glance



Detailed description:

- The attacker host performs three actions against Active Directory:
 1. LDAP/AD reconnaissance of users/descriptions/SPNs.
 2. Kerberos TGS request targeting the Kerberoasting tripwire account.
 3. Kerberos AS-REQ targeting the AS-REP Roasting tripwire account (pre-auth disabled).

- Domain Controllers log relevant Windows Security Events (commonly 4625, 4768, 4769, and 4771).
- AD Tripwires monitors for tripwire account interactions and emits deterministic trip events with context (tripwire account name, source host/user, DC observed, timestamp).
- The platform forwards alerts to Splunk Cloud or Microsoft Sentinel (or your SIEM/EDR) via built-in integrations for analyst triage and playbook execution.

Detection Tuning Tips

Keep the signal sharp with a few deliberate moves: allowlist any scanner or asset-inventory hosts that legitimately touch the tripwire accounts, crank severity when a single source brushes multiple tripwires in a short window, correlate trip events with spikes in LDAP user/SPN enumeration, and enrich the alert payload with network zone or asset criticality so analysts know whether they are looking at a lab VM or a domain controller.

What This Stops in Practice

Those small adjustments shut down the patterns we keep seeing in real environments: recon that turns into password spraying against “obvious” description strings, Kerberoasting that feeds offline cracking rigs, and AS-REP Roasting against forgotten legacy users. Forcing an operator to touch a tripwire that looks authentic converts quiet, native traffic into deterministic, actionable detections.

What AD Tripwires Won’t Detect

Tripwires only see the interactions that reference them. Credential abuse that never hits the planted accounts (pass-the-hash, token theft), golden/silver ticket usage, the actual offline cracking phase, or legitimate admin work untouched by the lures will flow past. Treat AD Tripwires as an early-warning layer that augments, not replaces, the rest of your SIEM/EDR and identity controls.

MITRE ATT&CK Mapping

- **Discovery:**
 - [T1087 Account Discovery](#)
 - [T1069 Permission Groups Discovery](#)
 - [T1482 Domain Trust Discovery](#)
- **Credential Access (Kerberos):**
 - [T1558.003 Kerberoasting](#)
 - [T1558.004 AS-REP Roasting](#)

Where to Go Next

- **Validate your environment:** do real accounts have SPNs that shouldn't? Any users with pre-auth disabled? Descriptions with secrets?
- **Turn on AD Tripwires:** seed the tripwire accounts, verify event flow, and test with your red team to see the alerts end-to-end.
- **Fold the alerts into response playbooks:** isolate source hosts, snapshot volatile evidence, and hunt for adjacent enumeration.
- **Run a safe test:** trigger each tripwire account to validate end-to-end alert routing and playbook activation before production rollout.

For deployment and operational guidance, see the AD Tripwires documentation and product pages in Related Reading.

Related Reading

- [Part 1: The Quiet Attack Path—How Attackers Own Active Directory in Minutes](#)
- [From CVE-2022-33679 to Unauthenticated Kerberoasting \(Horizon3.ai research\)](#)
- [H3-2021-0038 \(Horizon3.ai Knowledge Base\)](#)
- [Metrics That Matter: An Attacker's Perspective on Assessing Password Policy](#)
- [NodeZero Tripwires overview \(product\)](#)
- [AD Tripwires product page](#)